

CEHv13 A.I MODULE 09- SOCIAL ENGINEERING

Notes by VIVEK GOSWAMI

INTRODUCTION

Social Engineering is the art of manipulating people into revealing confidential information, performing actions, or granting access to systems without realizing the security risks involved.

Instead of directly attacking systems, attackers exploit human psychology to bypass security measures.

Objectives

- Understand the psychology behind social engineering attacks
- Learn different types of social engineering techniques
- Master prevention and detection strategies
- Gain hands-on experience with social engineering tools
- Develop security awareness training programs

What is Social Engineering?

Social engineering is an act of stealing information from humans. It's a mind manipulation technique.

1. No interaction with the target system or network
2. Non-technical attack
3. Convincing the target to reveal information
4. One of the major vulnerabilities that leads to this type of attack is **Trust**
5. User trusts another user and does not secure their credentials from them
6. Employees are uneducated in organisations, so this is a major vulnerability
7. Lack of security policies and privacy also makes it vulnerable

There are many ways in which companies may be vulnerable to social engineering attacks. These include:

- Insufficient security training
- Unregulated access to information
- An organisational structure consisting of several units
- Non-existent or lacking security policies

Common Types of Social Engineering Attacks include:

- **Phishing:** Fake emails or websites trick users into giving credentials.
- **Spear Phishing:** Targeted phishing attacks on specific persons or organisations.
- **Vishing:** Voice phishing using phone calls.
- **Smishing:** SMS-based phishing attacks.
- **Pretexting:** Fabricating a scenario to gather personal information.
- **Baiting:** Offering something attractive (like a free USB drive) to trick users.
- **Tailgating/Piggybacking:** Following authorized personnel into restricted areas.
- **Quid Pro Quo:** Offering a service in exchange for confidential information.

Phases in Social Engineering

1. Research

- Collection of information from the target organisation
- Collected by dumpster diving, scanning, searching on the internet, etc.

2. Select target

- Select the target among other employees
- A frustrated target is more preferred

3. Relationship

- Create a relationship with the target
- Earn the trust

4. Exploit

- Collecting sensitive information such as usernames, passwords, etc.

Types of Social Engineering

1. Human-based Social Engineering

One-to-one interaction with the target. Earn the trust to gather sensitive information from the target.

1. Impersonation

Definition:

The attacker pretends to be someone with authority or familiarity to gain trust.

How it works:

They use uniforms, fake badges, confident language, or knowledge of internal processes to deceive.

Example:

Someone dressed as a network technician shows up at an office claiming they need to “check the server lines,” and an employee lets them in without verification.

2. Pretexting

Definition:

A fabricated scenario is created to manipulate a victim into giving information or performing actions.

How it works:

The attacker gathers partial info and builds a believable story.

Example:

An attacker calls HR pretending to be an auditor and asks for employee records “to verify compliance.”

3. Physical Baiting

Definition:

Placing physical devices that lure victims into interacting with them.

How it works:

The attacker leaves USB drives, CDs, or gadgets in areas where employees might pick them up.

Example:

A USB labelled “Confidential Layoff List” is found in the parking lot. An employee plugs it into a work computer, triggering a malware payload.

5. Quid Pro Quo

Definition:

The attacker offers a service or reward in exchange for information or access.

How it works:

They pretend to be helpful to extract valuable data.

Example:

A fake “IT support technician” calls random staff offering to fix an issue, then asks the victim to share their login details to “reset” their system.

6. Shoulder Surfing and Eavesdropping

Stealing sensitive information by directly observing someone’s screen or input.

Eavesdropping is a technique in which an attacker reveals information by listening to the conversation

-Reading or accessing any source of information without being notified

Shoulder Surfing is a method of gathering information by standing behind the target

How it works:

Attackers take advantage of crowded or public environments.

Example:

Someone at an ATM stands close enough to see the user’s PIN as they type it.

7. Dumpster Diving

Definition:

Retrieving valuable info from trash.

- Looking for treasure in trash
- Searching through discarded documents and materials

How it works:

Attackers look for discarded documents, printouts, storage devices, or packaging.

Example:

Found shredded documents are pieced back together to obtain employee contact lists or internal memos.

Computer-Based Social Engineering Attacks

1. Phishing

Definition:

Mass fraudulent emails or messages are used to deceive victims into clicking on malicious links or providing information.

The attacker sends fake emails that look like legitimate emails

1. They're sent to hundreds, sometimes thousands, of recipients
2. When recipient opens the link, they are enticed to provide information
3. Attacker uses IDN Homographic Attack (International Domain Name)
4. In this, the attacker uses Cyrillic script to register a domain name and create a fake website similar to the actual website

How it works:

Relies on urgency, fear, or curiosity.

Example:

Email states: "Your account will be suspended in 12 hours. Verify now," with a link to a fake login page.

Example of phishing email

subject = "Important: Update Your Account Information"

body = ""

Dear User,

We noticed some unusual activity on your account. Please update your account information by clicking the link below:

<http://fake-login-page.com>

Thank you,

Your Bank

2. Spear Phishing**Definition:**

Targeted phishing attack tailored to a specific person or group.

Spear phishing is a targeted cyber attack where attackers send deceptive emails or messages to specific individuals or organisations. These emails appear to come from trusted sources and often contain malicious links or attachments designed to steal sensitive information or install malware. The goal is to exploit human psychology rather than technical vulnerabilities.

How it works:

Attackers research the victim's role, habits, or personal info.

Performing spear phishing in short:

1. Research your target to collect personal and professional information.
2. Craft a convincing, personalised email that appears to be from a trusted source.
3. Include a malicious link, attachment, or request for sensitive info tailored to the target.
4. Send the email, ensuring it bypasses basic security filters.
5. Wait for the victim to take the bait by clicking the link or providing information.

6. Exploit the gained access for further actions.

Example:

An email is sent to the finance manager referencing an internal project and includes a malicious “invoice” attachment.

3. Whaling**Definition:**

Phishing aimed at high-level executives.

Whaling attack targets senior management and highly privileged roles. Senior employees commonly have a lot of information in the public domain, and an attacker can use this information to craft highly effective attacks.

How it works:

Messages mimic business communications like legal threats or financial approvals.

Example:

A fake email from “legal department” demands the CEO review an attached “pending court notice.”

4. Vishing (Voice Phishing)**Definition:**

Social engineering attack executed over phone calls. Attacker use phone calls to trick people into sharing personal information

How it works:

Attackers use caller ID spoofing, urgency, or fear tactics.

Example:

A caller impersonates a bank representative and asks you to “confirm your card number to stop a fraudulent transaction.”

5. Smishing**Definition:**

Phishing is conducted via SMS or messaging apps.

An attacker sends a fake text message that requests a reply or contains a link to a phishing website.

How it works:

Short messages push malicious links or demand quick action.

Example:

“Your package is waiting. Pay ₹20 service fee to release it,” with a fake payment link.

6. Digital Baiting

Definition:

Offering downloadable content that hides malware.

How it works:

Victims think they’re downloading premium or pirated content.

Example:

A website offers a “free cracked version” of a paid app that actually installs spyware.

7. Fake Websites / Spoofing

Definition:

Creating websites that look identical to legitimate ones.

How it works:

Victims enter their credentials assuming the site is real.

Example:

A login page mimics Instagram or a banking portal and collects the username and password.

8. Social Media Engineering

Definition:

Using fake profiles, manipulated posts, or direct messages to extract information.

How it works:

Attackers exploit trust, oversharing, or emotional triggers.

Example:

A fake recruiter on LinkedIn sends a “job application form” containing malware.

Mobile-Based Social Engineering

Mobile-based social engineering refers to the use of social engineering techniques on mobile devices to trick users into revealing sensitive information or performing actions that compromise their security. Here are some common techniques used in mobile-based social engineering:

1. **Fake Apps:** Attackers create fake apps that mimic legitimate apps, such as banking apps or social media apps. These apps may ask for sensitive information, such as login credentials or personal details.
2. **SMS Phishing:** Attackers send SMS messages that appear to come from legitimate sources, such as banks or service providers. These messages may contain malicious links or ask for sensitive information.
3. **QR Code Scams:** Attackers create fake QR codes that redirect users to malicious websites or download malicious apps.
4. **Wi-Fi Scams:** Attackers set up fake Wi-Fi networks that mimic legitimate networks, such as public Wi-Fi networks. Users who connect to these networks may be vulnerable to attacks.
5. **Social Media Scams:** Attackers use social media platforms to trick users into revealing sensitive information or performing actions that compromise their security.

To protect against mobile-based social engineering, users should:

1. **Verify App Sources:** Only download apps from official app stores, such as Google Play Store or Apple App Store.
2. **Be Wary of SMS Messages:** Be cautious when receiving SMS messages from unknown sources, especially if they contain suspicious links or requests for sensitive information.
3. **Use Secure Wi-Fi Networks:** Avoid connecting to public Wi-Fi networks, especially if they do not require a password.
4. **Use Two-Factor Authentication:** Use two-factor authentication whenever possible to add an extra layer of security to your accounts.
5. **Stay Alert:** Stay alert to potential social engineering attempts and report any suspicious activity to your service provider or security team.

Impersonation on Social Network Sites

Social Engineering Through Impersonation on Social Network Sites

1. An attacker gathers personal information of a target from different sources, mostly from social network sites
2. Information includes: full name, date of birth, email address, residential address, etc.
3. After gathering the information, the attacker creates an account that is the same
4. Then introduces to friends, groups joined by the target to get updates or convince the target's friends to reveal information

Risks of Social Networks in Corporate Networks

1. Social network sites are not as secure as a corporate network secures the authentication
2. The major risk of social networks is their vulnerability in authentication
3. The employee, while communicating on social networks, may not take care of sensitive information

Identity Theft

1. Stealing the identification information of someone
2. Popularly used for fraud
3. Prove the fake identity to take advantage of it

DETECT PHISHING ATTACK

1. DETECT PHISHING USING NETCRAFT

The Netcraft anti-phishing community is a giant neighbourhood watch scheme, empowering the most alert and most expert members to defend everyone within the community against phishing attacks. The Netcraft Extension provides updated and extensive information about sites that users visit regularly; it also blocks dangerous sites. This information helps users to make an informed choice about the integrity of those sites.

Url- <https://www.netcraft.com/resources/apps-and-extensions>

Addon to detect phishing website.

2. DETECT PHISHING USING PHISHTANK

You can check the status of any phishing site.

Url- <https://phishtank.org/>

POPULAR TOOLS USED FOR SOCIAL ENGINEERING:

- **SET (Social-Engineer Toolkit):** Open-source tool designed for advanced phishing and credential harvesting simulations, ideal for penetration testing. It's Python-based and command-line focused.
- **Gophish:** An easy-to-use open-source phishing framework optimised for security awareness training with customizable templates, real-time tracking, and campaign automation.
- **King Phisher:** A phishing campaign management tool that helps organise and automate phishing tests with customizable emails and landing pages.
- **OSINT Tools (Maltego, Recon-ng, theHarvester):** Reconnaissance tools used to gather detailed target information to craft tailored social engineering attacks.

SOCIAL ENGINEERING USING A.I

AI automates the creation of realistic phishing emails, convincing pretext scenarios, and strategic baiting tactics.

CRAFT PHISHING EMAIL USING CHATGPT

PROMPT- "Pose as a genuine Microsoft customer support executive with imaginary name, write a concise email stating that he/she has found a suspicious login on the user's account and ask them to reset the password on an urgent basis. Provide the reset link at [Fake Reset Link]."

COUNTERMEASURES

- Conduct regular employee training and awareness programs to recognise social engineering tactics.
- Establish clear company-wide security policies and procedures addressing social engineering threats.
- Enforce strong identity and access management with multi-factor authentication and least privilege principles.
- Implement technical defences, including email filtering (anti-phishing), DNS filtering, and endpoint detection systems.

- Physically secure premises using badges, tailgating prevention, and visitor access protocols.
- Promote a culture encouraging reporting of suspicious emails or behaviours without fear.
- Perform regular penetration testing, including social engineering exercises.
- Monitor network and user behaviour continuously for anomalies.
- Use secure methods for verifying identity before resetting passwords or granting access.
- Maintain incident response plans specifically for social engineering attacks and conduct post-incident analysis.